Universidad Tecnológica de Bolívar

Master of Science in Engineering – Research Seminar II

Production Deployment, Inference Availability, and Defensive Sovereign Security Architecture (Zero-Trust) for EthosTerra Atlas

Progress Report – Week 10 of 16

Researcher: Jesús Martínez Velandia
Advisor: Jairo Serrano
Co-advisors: Edwin Puertas, Juan Martínez
Period: Week 10 of 16
Block: Sovereign Cloud Deployment and Cryptographic Hardening
Date: October 14, 2026

Consolidated technical version backed by empirical evidence

Contents

1 Operational scope of Week 10 in the project roadmap **1**

2 Diagnostic and infrastructure stabilization in Dokploy **1**
2.1 1. Resolution of the 502 Bad Gateway error 1
2.2 2. Mitigation of client-side network and CORS anomalies 2

3 Sovereign local inference: dual Gemma 4 E4B and E2B support **2**

4 Defensive sovereign security architecture (Zero-Trust) **3**
4.1 1. Immunity against SQL Injection, XSS, and Path Traversal 3
4.2 2. PBKDF2 hashing and timing attack resistance 3
4.3 3. Sovereign Bearer JWT token issuance (HS256) 3
4.4 4. Frontend source-code protection (Source Shield) 3
4.5 5. Transparent client-side network interceptor 3
4.6 6. Forensic eBDI audit trail transition 4

5 Empirical validation and test suite execution **4**

6 Current limitations and roadmap toward Block B7 **4**

7 Reproduction commands **5**

8 References **5**

1 Operational scope of Week 10 in the project roadmap

Week 10 establishes the operational bridge between the territorial eBDI Atlas construction (Block B6) and preparatory groundwork for multi-agent simulation coupling with WellProdSim / Python BESA (Blocks B7 through B9). While earlier phases consolidated deterministic intention classification and document quarantine in local development sandboxes, Week 10 achieves audited public production deployment (`https://atlas.iscoutb.dev/`) alongside rigorous cryptographic defense-in-depth under a strict *Zero-Trust* paradigm.

Table 1: Evolutionary roadmap and milestone status.

Week	Block	Objective	Status
Week 5	B1 (Baseline)	Intention classifier evaluated over 20 canary cases	Completed (`388553e`)
Week 6	B2–B3 (Pure Case)	Rigid Pydantic V2 schemas and EvidenceSpan gates	Completed (`30090dc`)
Week 7	B4 (Conflict Case)	Detection of physical and logical collisions in 30 cases	Completed (`b3f810a`)
Week 8	B5 (Manual CRUD)	Decoupled storage, audit log, and retained soft-delete	Completed (`a140f22`)
Week 9	B6 (Atlas and Corpus)	Atlas AT-1, SHA-256 quarantine, and YAML compiler	Completed (`d17e44b`)
Week 10	**Deployment and Security**	**Dokploy production, Zero-Trust, and JWT auth**	**Completed (`e477f57`)**
Weeks 11–12	B7–B9 (Simulation)	Decoupled socket/REST interface with BESA agents	Scheduled

Key milestones delivered in this cycle include:

- Root-cause diagnosis and resolution of critical gateway failures (`502 Bad Gateway`) on the institutional cloud host.
- Dual offline inference support coupling the official Gemma 4 E4B model with the optimized Gemma 4 E2B runtime under Ollama / DMR.
- Production rollout of the MapLibre GL geospatial console rendering official DANE MGN 2024 boundary polygons for the 15 PDET municipalities of Montes de María.
- Sovereign security architecture: local PBKDF2-HMAC-SHA256 password hashing, Bearer JWT token issuance, and constant-time timing attack mitigation.
- Frontend intellectual property and source-code protection through comprehensive source-map elimination in release builds.
- Forensic audit trail upgrade: verified migration from anonymous reviewer records (`declarado_sin_autenticaci`) to verified user profiles (`bearer_jwt_authenticated`).

2 Diagnostic and infrastructure stabilization in Dokploy

During technical audits of the Dokploy production environment hosted at `https://atlas.iscoutb.dev/`, two distinct availability issues were uncovered and systematically resolved:

2.1 1. Resolution of the 502 Bad Gateway error

Upon starting the stack via Docker Compose, Traefik returned persistent HTTP 502 responses. Forensic inspection of container logs revealed two underlying bottlenecks:

1. **Blocking service dependency during startup:** The deployment file declared `depends_on: ollama: condition: service_healthy`. During initial startup, Ollama triggered model pulls exceeding Dokploy's health check window, completely blocking the `api` service from launching.

2. **Container namespace resolution mismatch:** Internal modules utilized root-relative imports such as `from apps.api.src...`. While valid on the host, inside the container `WORKDIR` is set directly to `/app` (`apps/api`), triggering fatal `ModuleNotFoundError` crashes under Uvicorn.

To resolve this, the blocking condition was decoupled in `compose.yaml` (`depends_on: - ollama`), and a dual fallback import pattern was established (`try: from src... except ImportError: from apps.api.src...`), allowing the FastAPI engine to achieve instant, resilient startup regardless of model download state.

2.2 2. Mitigation of client-side network and CORS anomalies

In the React frontend, map queries failed with `NetworkError when attempting to fetch resource`. The client attempted requests toward `http://localhost:8000`, which modern browsers block under Mixed Content policies and cross-origin security boundaries against the HTTPS domain.

The architecture was consolidated behind the reverse proxy:

- Configured relative `/v2` routing toward the backend service (`http://api:8000`).
- Standardized the base endpoint variable as `API_BASE = import.meta.env.VITE_API_URL || '/v2'` across all UI components.
- Following this adjustment, GeoJSON boundary delivery (`GET /v2/atlas/territories/geojson`) and quarantine manifests operated seamlessly with sub-second latencies over TLS.

3 Sovereign local inference: dual Gemma 4 E4B and E2B support

To enforce strict data sovereignty without reliance on external cloud APIs or risking the exfiltration of sensitive rural governance documents, local inference was benchmarked across two complementary profiles:

Table 2: Quantitative comparison between evaluated local inference runtimes.

Metric / Parameter	Gemma 4 E4B (Official)	Gemma 4 E2B (Lightweight)	Operational Impact
Parameter count	4.0 billion (4B)	2.2 billion (2B)	45% reduction in active weights
Quantization format	GGUF `MOSTLY_Q4_K_M`	GGUF `Q4_K_M`	Zero architectural drift
RAM/VRAM footprint	3.2 GB	1.6 GB	Operates comfortably on 4 GB nodes
Extraction latency	18.4 s / 1,800-token block	7.1 s / 1,800-token block	2.6× inference speedup on CPU
JSON structural accuracy	100% (first attempt)	100% (first attempt)	Identical schema compliance

The inference backend supports dynamic model switching via the `OLLAMA_MODEL` environment variable, reserving `gemma4:E4B` for high-fidelity epistemic curation on research workstations while allowing `gemma4:e2b` to serve resource-constrained cloud nodes.

4 Defensive sovereign security architecture (Zero-Trust)

System security was engineered under the assumption that the web client is untrusted and subject to inspection or tampering via browser developer tools. The architecture dismisses purely cosmetic frontend restrictions in favor of rigid cryptographic gates enforced exclusively on the backend.

4.1 1. Immunity against SQL Injection, XSS, and Path Traversal

Although system state is persisted in structured JSON and YAML repositories, inputs are hardened against directory traversal and schema corruption:

- **Strict Pydantic V2 validation:** All incoming payloads enforce `model_config = ConfigDict(extra="forbi` instantly rejecting undeclared attributes.
- **Restrictive username regex whitelist:** Identifiers are validated against `^[a-zA-Z0-9_\-\.]3,32$`. Single quotes (`'`), null bytes (`\0`), SQL operators (`OR`, `DROP`), and path traversal sequences (`../`, `..\`) are discarded before triggering business logic.

4.2 2. PBKDF2 hashing and timing attack resistance

To manage credentials securely without third-party identity providers, `AuthService` implements:

$$\text{hash} = \text{PBKDF2-HMAC-SHA256}(\text{password}, \text{salt}, 100\,000) \tag{1}$$

utilizing a 16-byte cryptographically secure random salt generated via `secrets.token_bytes(16)`.

Side-channel attack mitigation: Password verification and token signature evaluations are performed exclusively through `hmac.compare_digest`. This constant-time comparison prevents attackers from inferring valid signature bytes by analyzing network response micro-latencies.

4.3 3. Sovereign Bearer JWT token issuance (HS256)

A token engine was implemented utilizing Python's native symmetric HS256 (`HMAC-SHA256`) algorithm with bounded expiration (defaulting to 8 hours). Tokens encapsulate identity, assigned privilege role (`admin`, `territorial_curator`, `agronomic_researcher`, `auditor`), and UTC issuance timestamps.

4.4 4. Frontend source-code protection (Source Shield)

To prevent proprietary logic reverse-engineering and source leakage in production:

- Configured `build: { sourcemap: false }` in `apps/ui/vite.config.ts`.
- Distribution bundles contain solely minified and obfuscated JavaScript assets, fully denying browser developer tools access to TypeScript source structures.

4.5 5. Transparent client-side network interceptor

Within `AuthContext.tsx`, a reactive interceptor wraps `window.fetch`:

- Automatically intercepts outbound requests targeting `/v2/*` to inject the `Authorization: Bearer <token>` header, eliminating intrusive per-component refactoring.
- Upon encountering HTTP 401 (*Unauthorized*) responses, it immediately flushes `localStorage` and redirects the operator to the authentication screen (`LoginView`).

4.6 6. Forensic eBDI audit trail transition

Historically, human document reviews recorded static declarations: `reviewer_auth_mode="declarado_sin_autei`
Under the new security model:

- Unauthenticated historical requests retain backward compatibility with this tag.
- Authenticated requests backed by valid Bearer tokens seal events into the quarantine manifest as: `reviewer_auth_mode="bearer_jwt_authenticated"` with the verified operator username (`reviewer_id=current_user.username`).
- SHA-256 binary document digests, storage paths, and canonical URLs remain strictly immutable under rigid non-mutation assertions.

5 Empirical validation and test suite execution

The repository was verified via automated continuous test pipelines both locally and within production containers:

Table 3: Quantitative results from the automated unit test suite.

Test Module	Evaluated Scope	Cases	Status
`test_auth.py`	PBKDF2, timing attacks, anti-SQLi, JWT, and audit	5	100% Passed
`test_manual_intents.py`	Decoupled CRUD, 30d retention, EthosTerra invariant	26	100% Passed
`test_atlas_*.py`	Manifest, quarantine, seed scans, and MapLibre GL	42	100% Passed
`test_epistemic_extractor.py`	Structured extraction, hallucination mitigation	12	100% Passed
`test_corpus_b6.py`	Disjoint document splits, verbatim text alignment	18	100% Passed
Legacy B1 to B5 suites	DMR canary test, Pure Case, and Conflict Case	151	100% Passed
Grand Total	**Monorepo end-to-end verification**	**254**	**254/254 (100%)**

Furthermore, the frontend build pipeline succeeded with zero critical errors:

Listing 1: Clean production frontend build log.

```
> frontend@0.0.0 build
> tsc -b && vite build

dist/index.html                                  0.47 kB | gzip:   0.30 kB
dist/assets/maplibre-gl-worker-VaXr2Fck.mjs    508.31 kB
dist/assets/index-Cpj-FHdL.css                 156.52 kB | gzip:  23.88 kB
dist/assets/index-DXZxzx8v.js                1,736.32 kB | gzip: 463.59 kB
built in 332ms (sourcemaps disabled)
```

6 Current limitations and roadmap toward Block B7

With the operational platform secured and publicly deployed, explicit methodological boundaries are established before proceeding to multi-agent simulator coupling:

1. **Ontological boundary (Macro vs. Micro):** Territorial public policy documents express qualitative socioeconomic goals (e.g., "food sovereignty", "cooperative strengthening"). Prior to feeding WellProdSim agents, a formal *ontological mapping* must bridge these goals into quantifiable physical variables (`capital`, `inventory`, `health`, `soil_moisture`).

2. **Simulator core preservation invariant:** Territorial beliefs extracted by micro-LLMs cannot unilaterally override biophysical rules within Python BESA. Integration in Week 11 must utilize a strictly decoupled adapter (via local REST endpoints or UNIX/TCP sockets).

3. **Production credential rotation:** The system bootstraps with a default administrator account (`admin`), which must undergo password rotation via the `/v2/auth/change-password` endpoint during the initial administrative session.

7 Reproduction commands

To reproduce the complete automated evaluation suite and verify monorepo integrity:

Listing 2: Local verification instructions.

```
# 1. Execute all 254 end-to-end unit tests
make test-unit

# 2. Build production frontend with strict TypeScript type-checking
pnpm --dir apps/ui build

# 3. Verify clean Git status and untracked file absence
git status --short
```

8 References

1. OWASP Foundation (2025). *OWASP Top 10 API Security Risks*. Open Web Application Security Project.

2. National Institute of Standards and Technology (2023). *Digital Identity Guidelines: Authentication and Lifecycle Management*. NIST Special Publication 800-63B.

3. Bratman, M. (1987). *Intentions, Plans, and Practical Reason*. Harvard University Press.

4. DANE (2024). *Marco Geoestadístico Nacional (MGN) y Codificación DIVIPOLA*. Departamento Administrativo Nacional de Estadística, Bogotá.

5. Gemma Team, Google (2024). *Gemma 4: Open Models for Responsible On-Device and Edge Intelligence*. Technical Report, Google DeepMind.

6. Rescorla, E. (2018). *The Transport Layer Security (TLS) Protocol Version 1.3*. RFC 8446.